ISO 27001 (ISMS) 初心者向けガイド

信頼の「要塞」を築く国際規格

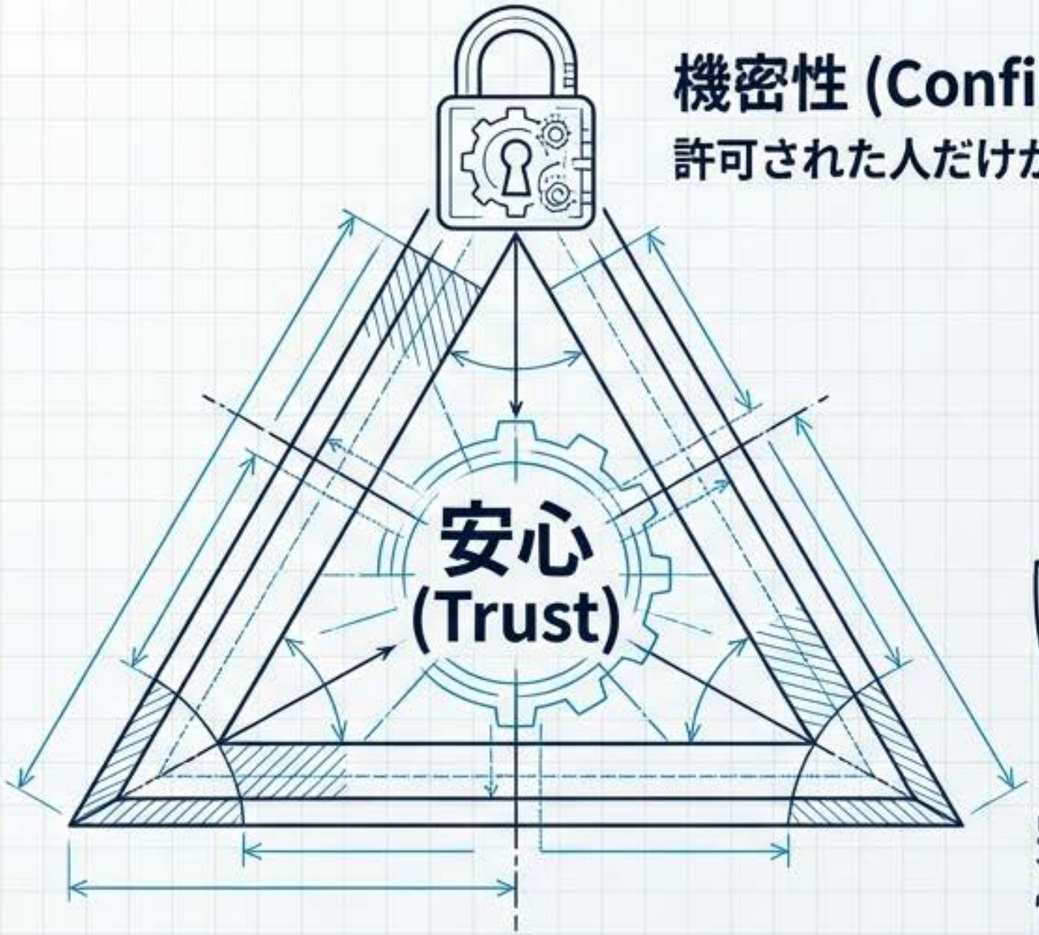
仕組み・メリット・導入ロードマップを10枚で完全解説

Based on the 2022 Revision (ISO/IEC 27001:2022 / JIS Q 27001:2023)

NotebookLM

情報セキュリティとは、「ハッカー対策」だけではありません。

ビジネスの継続と信頼を守るための「3つの要素（CIA）」



機密性 (Confidentiality)
許可された人だけがアクセスできること

可用性 (Availability)
必要な時にいつでも情報が使えること

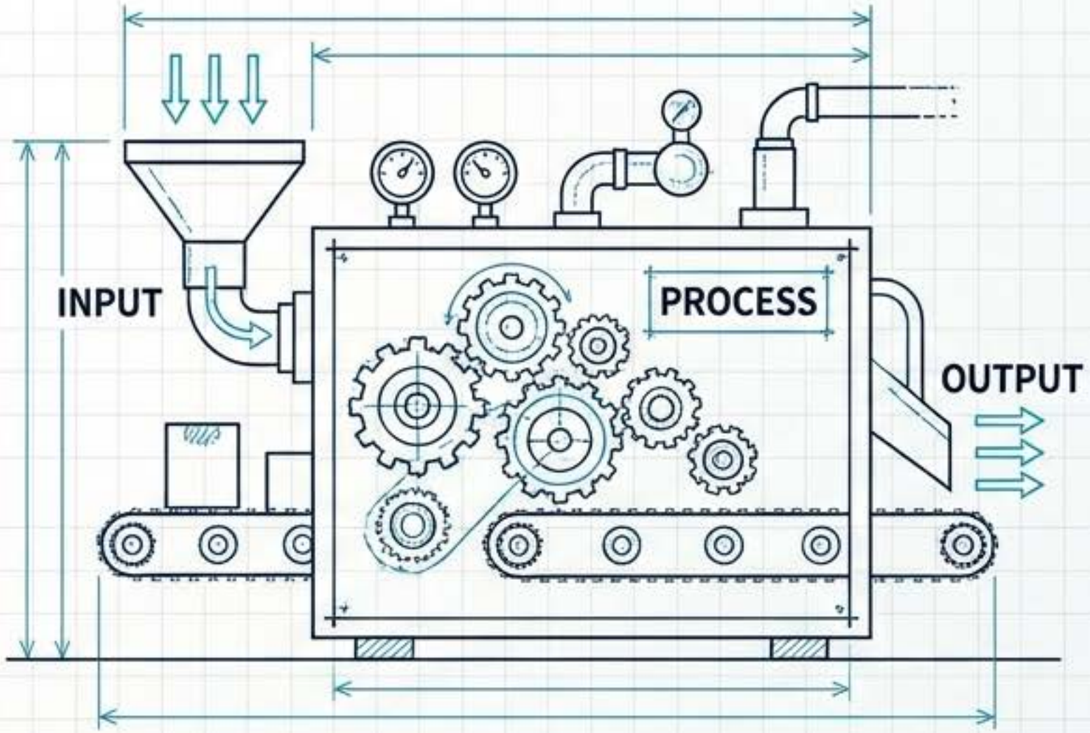
完全性 (Integrity)
情報が正確で、改ざんされていないこと

ISMSの目的は、この3つのバランスを維持することです。

NotebookLM

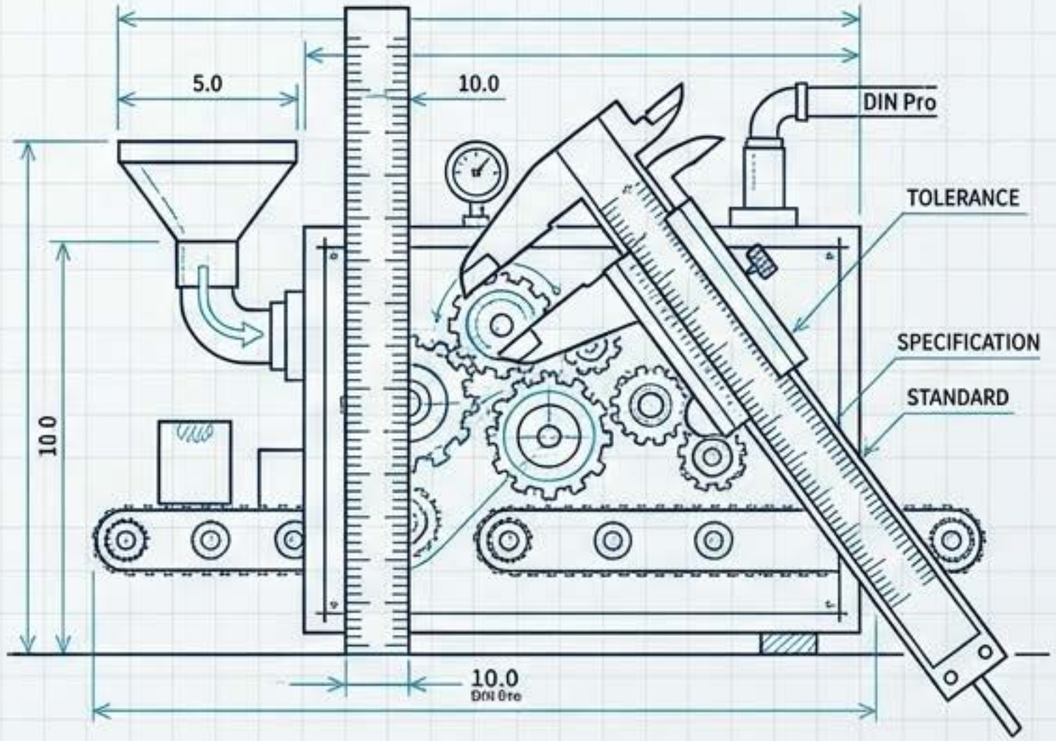
「ISMS」と「ISO 27001」の違いとは？

ISMS (System)



組織の情報を守るための「仕組み」
そのもの（特注の機械）。

ISO/IEC 27001 (Standard)

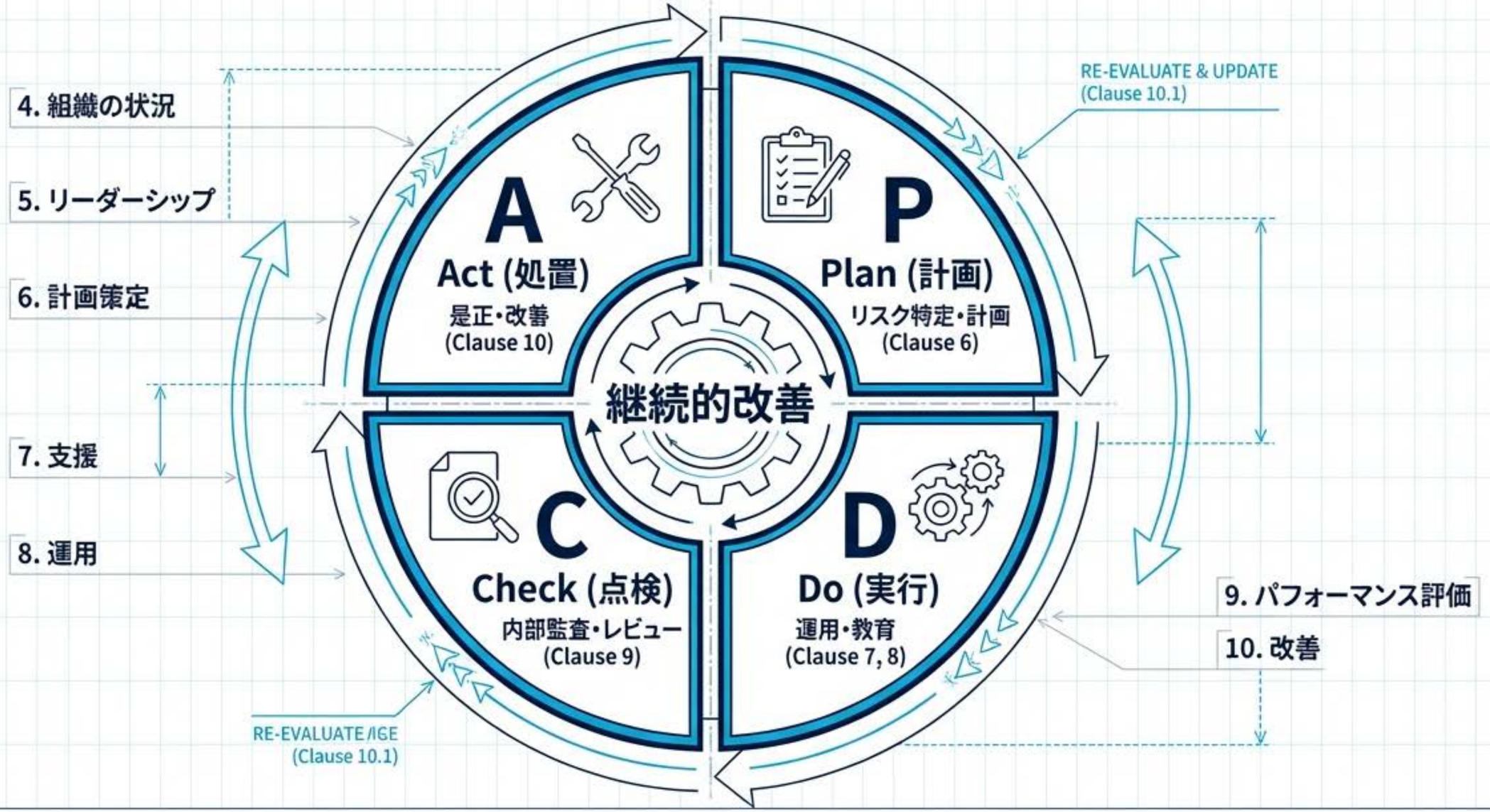


仕組みが適切か評価するための
「国際的な要求事項」（定規）。

一般的に「ISMSを取得する」＝「ISO 27001の認証を取得する」と同義です。

NotebookLM

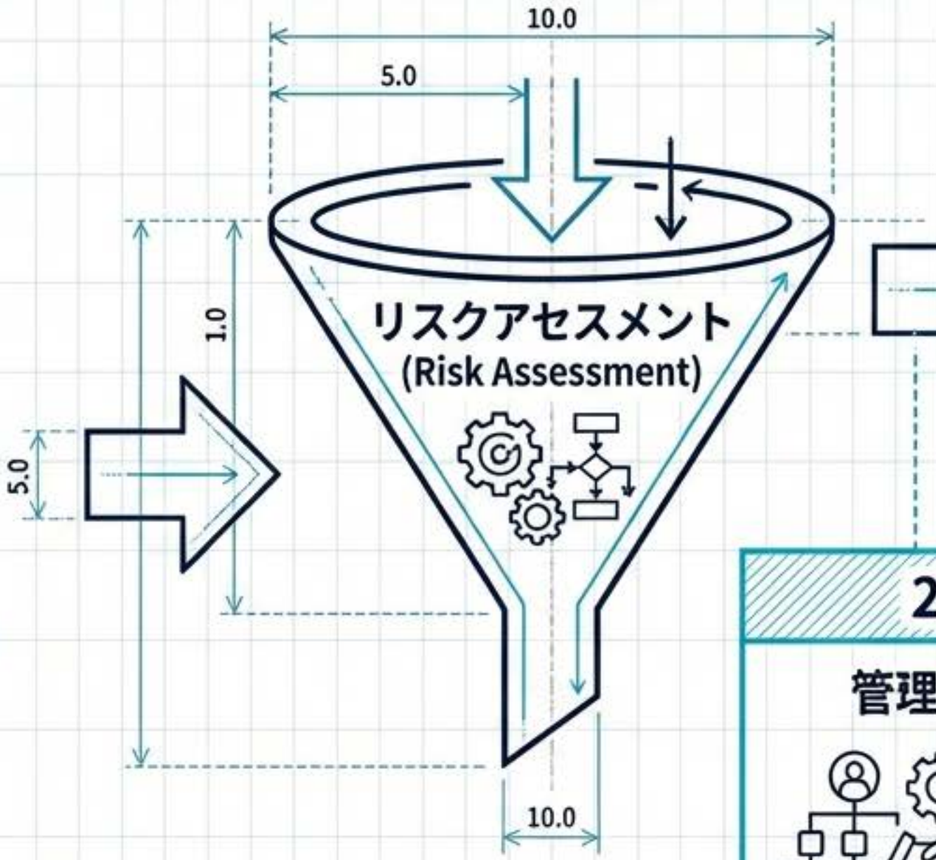
認証はゴールではありません。「運用」と「改善」のサイクルです。

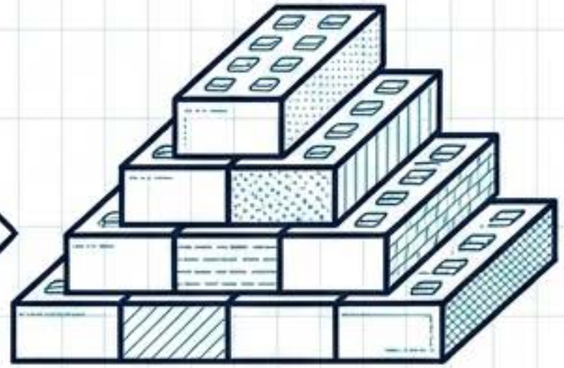


NotebookLM

どのリスクを防ぐのか？「リスクアセスメント」と「管理策」

全てのリスク
(All Risks)





必要な管理策 (Annex A)

2022年版の変更点 (Update)

管理策は 114項目 → 93項目 に統合

組織的
(Organizational)

人的
(People)

物理的
(Physical)

技術的
(Technological)

クラウドセキュリティや脅威インテリジェンスが追加

NotebookLM

「ISO 27001」と「ISO 27002」の関係性

ISO/IEC 27001 (JIS Q 27001)

認証基準
(Requirements)

「何をしなければならないか (What)」を規定。
必ず守る必要があるルールブック。

27002を参照して
27001の対策を決める

ISO/IEC 27002

実践のガイドライン
(Code of Practice)

「どうやって実施するか (How)」のベストプラクティス集。
対策を考えるための教科書。

NotebookLM

ISO 27001とプライバシーマーク（Pマーク）の違い

	ISO 27001	プライバシーマーク（Pマーク）
Logo	CERTIFICATION ISMS-AC ISMS ISR000	PRIVACY MARK P 登録証号000一
保護対象	全種の情報資産 （技術・人事・顧客など）	個人情報のみ
適用範囲	部門単位でも可能（柔軟）	企業全体（全社必須）
規格	国際規格（Global）	国内規格（Japan Only）
アプローチ	オーダーメイド（リスクベース）	既製品（統一基準）

NotebookLM

認証取得までのロードマップ（標準期間：6ヶ月〜1年）

認証取得・登録

Phase 1
構築 (Months 1-4)

- キックオフ
- リスクアセスメント
- 文書作成

Phase 2
運用 (Months 5-7)

- 従業員教育
- 内部監査
- マネジメントレビュー

Phase 3
審査 (Months 8-10)

- 第一段階審査 (文書)
- 第二段階審査 (実地)

受ける組織
（企業・団体等）

→

認証機関
（審査登録機関）
- 審査員

→

認証取得

審査機関が審査を実施

NotebookLM

ISMS認証を取得する3つのメリット

社会的信頼の獲得（Trust）

- 入札要件のクリア、大手企業との取引条件達成、国際的な信用。

社内体制の強化（Governance）

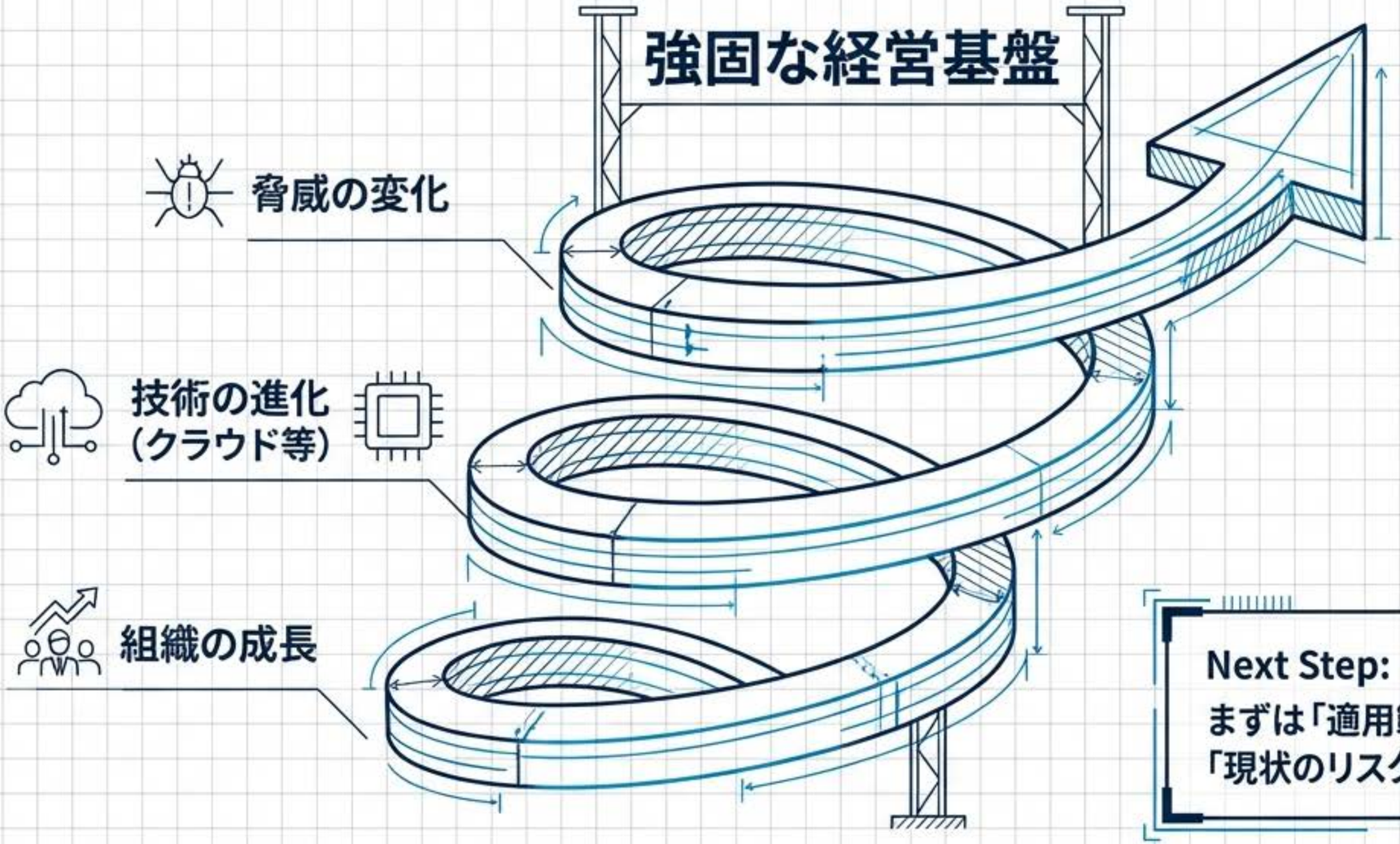
- ルールの明確化、
- 業務効率の向上、
- 属人化の解消。

リスクの低減（Security）

- 情報漏えい事故の予防、
- 万が一の際の事業継続性（BCP）。

NotebookLM

認証取得はスタートライン。変化に強い組織へ。



Next Step:
まずは「適用範囲」の決定と
「現状のリスク把握」から始めましょう。

ISO/IEC 27001:2022 / JIS Q 27001:2023 対応

NotebookLM